SITUS Protocol

Sensor-Integrated Trust Using Spatial Entropy

Prateek Singh

Independent Researcher

https://theaivibe.org

March 2026

Version 1.0

Abstract

Current authentication systems verify identity in isolation from physical context. A stolen credential works from any location in the world. This paper introduces **SITUS Protocol** — Sensor-Integrated Trust Using Spatial Entropy — a cryptographic framework that binds authentication events to the unrepeatable physical context in which they occur. SITUS formalizes **Environmental Entropy Vectors (EEVs)** as a cryptographic primitive, combining cross-correlated sensor data — RF environment, acoustic signatures, inertial measurements, atmospheric readings, electromagnetic fields, and network topology — into the authentication process. Through a commit-before-challenge protocol, cross-sensor consistency validation, adaptive risk thresholds, and temporal decay functions, SITUS ensures that credentials are not only non-transferable but *non-relocatable*: they function only in the physical context where they are used. We present the full protocol specification, security analysis against a powerful adversary model, and practical deployment considerations for critical infrastructure, financial systems, and remote work environments.

Keywords: authentication, environmental entropy, sensor fusion, context-aware security, physical layer security, non-relocatable credentials

1. Introduction

Every authentication system deployed today answers one question: *"Who are you?"* Passwords prove knowledge of a secret. Biometrics prove possession of a specific body. Hardware tokens prove possession of a specific device. Behavioral biometrics prove exhibition of a specific behavioral pattern. Each method verifies identity with increasing sophistication.

None of them answer a second, equally critical question: *"Where are you, right now, in the physical world — and can you prove it?"*

This gap is not theoretical. A compromised VPN credential works from Moscow as easily as from an authorized office in Virginia. A stolen biometric template can be replayed from any location. Even behavioral biometrics, while significantly harder to forge, operate

independently of physical context. The attacker does not need to be *where* the victim is — they only need to *be* the victim, digitally.

SITUS Protocol closes this gap by introducing a cryptographic primitive called an **Environmental Entropy Vector (EEV)**, which binds every authentication event to the unrepeatable physical context in which it occurs. The result: credentials that are not only non-transferable but *non-relocatable*.

2. Core Insight: Physical Entropy as a Cryptographic Primitive

At any given moment, a device exists in a unique physical context defined by dozens of measurable environmental signals:

- **RF environment:** The specific set of WiFi networks visible, their signal strengths, and their relative positions. Discoverable Bluetooth devices. Cellular tower IDs and signal characteristics.
- **Acoustic environment:** The ambient noise spectrum — HVAC hum frequency, traffic patterns, human activity. Not the content of sounds, but their spectral fingerprint.
- **Inertial environment:** Accelerometer noise floor, gyroscope drift patterns, device orientation relative to gravity. Even a stationary device has a characteristic vibration signature determined by the surface it rests on.
- **Atmospheric environment:** Barometric pressure, ambient light wavelength distribution, temperature (via battery charging characteristics).
- **Electromagnetic environment:** Magnetic field vector (influenced by building structure, nearby electronics, geographic location).
- **Network environment:** Latency fingerprints to distributed reference servers, packet jitter characteristics, route topology.

Individually, each signal carries limited entropy. An attacker could spoof GPS coordinates or fabricate a WiFi scan. But the **cross-correlation** of all signals simultaneously creates a context that is:

1. **High-entropy:** The combined state space across all sensors is astronomically large.
2. **Internally consistent:** Signals must agree — WiFi networks must match the geographic region implied by cell towers and network latency.
3. **Temporally unique:** The exact configuration never repeats, because environmental conditions continuously change.
4. **Physically bound:** Replicating the context requires physical presence in the same location.

SITUS formalizes this environmental context into a cryptographic primitive and integrates it into the authentication protocol.

3. Protocol Architecture

SITUS consists of five components that work together to bind identity to physical context.

3.1 Entropy Harvesting Layer (EHL)

The EHL runs on the authenticating device and collects environmental signals from all available sensors. It produces an **Environmental Entropy Vector (EEV)** — a structured, timestamped representation of the device's physical context.

The EEV is not a raw sensor dump. Each signal source is processed through a feature extraction pipeline that:

- Normalizes sensor data to device-independent representations
- Extracts stable features (WiFi BSSID set) and volatile features (signal strength fluctuations)
- Computes an entropy density score for each source, indicating how much randomness it contributes
- Strips privacy-sensitive content (audio is reduced to spectral features, never stored as recordings)

The resulting EEV is a fixed-length vector $E = (e_1, e_2, ..., e_n)$ where each e_i represents the processed output of one entropy source, accompanied by its entropy density score $H(e_i)$.

3.2 Commitment Engine (CE)

The Commitment Engine implements the critical **commit-before-challenge** protocol that prevents an attacker from fabricating environmental data after seeing the authentication challenge.

The protocol flow:

1. Device harvests EEV and computes commitment: $C = H(EEV \parallel nonce)$
2. Device sends commitment C to server (without revealing EEV)
3. Server generates random challenge R and sends it to device
4. Device computes context-bound signature: $\sigma = Sign(sk, R \parallel EEV \parallel timestamp)$
5. Device sends $(\sigma, EEV, nonce, timestamp)$ to server
6. Server verifies commitment, signature, and EEV validity

The commitment is essential. Without it, an attacker who intercepts the challenge could fabricate an EEV and compute a valid signature. With the commitment, the EEV is fixed before the challenge is known — the attacker cannot retroactively adjust the environmental data.

3.3 Cross-Sensor Consistency Validator (CSCV)

The CSCV is the server-side component that determines whether a submitted EEV is genuine or fabricated. It does not need to know the expected environment — it verifies *internal consistency*.

Check	What It Validates	Attack It Defeats
RF-Geo correlation	Visible WiFi BSSIDs are consistent with IP geolocation and cell tower data	Remote replay with spoofed GPS
Acoustic-Inertial correlation	Ambient noise patterns match accelerometer vibration	Selective sensor spoofing

Check	What It Validates	Attack It Defeats
Temporal consistency	Sensor readings change at physically plausible rates	Pre-recorded environment injection
Entropy density	Each source contributes minimum expected entropy	Synthetic data generation
Network-Physical correlation	Network latency consistent with claimed physical location	VPN/proxy-based location spoofing

The CSCV uses a learned model (trained on legitimate authentication events) to score consistency. The model outputs a **Context Authenticity Score (CAS)** between 0 and 1. Authentication requires CAS above a risk-dependent threshold.

3.4 Adaptive Threshold Module (ATM)

Not every authentication requires the same level of environmental proof. The ATM adjusts requirements based on risk level:

Risk Level	Required Entropy Sources	Min CAS	Example Operations
Low	2+ sources	0.6	Reading email, viewing dashboards
Medium	4+ sources including RF	0.75	Code deployment, document access
High	6+ sources with geo-network correlation	0.85	Financial transactions, admin access
Critical	All sources + multi-device correlation	0.95	Key ceremony, infrastructure changes

At the Critical level, SITUS requires **multi-device environmental correlation**: two or more devices belonging to the user must independently report consistent environmental context. An attacker would need to compromise multiple devices *and* be physically present — a dramatically harder attack.

3.5 Temporal Decay Function (TDF)

An authenticated session's validity decays as a function of environmental change rate. The TDF continuously monitors how rapidly the EEV is evolving:

- **Static environment** (office desk): Session validity up to 15 minutes
- **Slowly changing** (walking through a building): ~3 minutes
- **Rapidly changing** (moving vehicle): ~30 seconds
- **Discontinuous change** (device appears to teleport): Immediate termination

The decay function is: $V(t) = Vo \cdot e^{-\lambda \cdot \Delta E(t)}$, where $\Delta E(t)$ is the cumulative environmental change since the last authentication and λ is the risk-adjusted decay constant. When $V(t)$ drops below threshold, re-authentication is required.

This makes session hijacking ineffective. Even if an attacker captures an active session token, the session terminates as soon as the environmental context diverges.

4. Formal Protocol Specification

4.1 Authentication Phase

```
 1. Client:  E ← EHL.harvest()                  // Collect environmental entropy
 2. Client:  nonce ← random(256)                 // Generate random nonce
 3. Client:  C ← SHA3-256(E ‖ nonce)             // Compute commitment
 4. Client → Server:  C                           // Send commitment
 5. Server:  R ← random(256)                      // Generate challenge
 6. Server → Client:  R                           // Send challenge
 7. Client:  σ ← Ed25519.Sign(sk, R ‖ E ‖ t)     // Sign challenge + context
 8. Client → Server:  (σ, E, nonce, t)            // Send signature + context
 9. Server:  Verify SHA3-256(E ‖ nonce) == C      // Check commitment
10. Server:  Verify Ed25519.Verify(pk, σ, R ‖ E ‖ t) // Check signature
11. Server:  Verify |t - t_server| < Δt_max       // Check timestamp freshness
12. Server:  Verify C ∉ BloomFilter               // Check replay
13. Server:  CAS ← CSCV.validate(E)               // Cross-sensor consistency
14. Server:  Verify CAS ≥ threshold(risk)          // Check context authenticity
15. Server:  BloomFilter.insert(C)                 // Record commitment
16. Server:  Return (session_token, V₀, λ)        // Issue decaying session
```

4.2 Session Maintenance

```
Every interval Δt:
1. Client:  E' ← EHL.harvest_lightweight()      // Low-power sensor check
2. Client:  ΔE ← distance(E_last, E')           // Compute environmental drift
3. Client:  V(t) ← V₀ · e^(-λ · ΔE_cumulative) // Compute session validity
4. If V(t) < threshold: trigger re-authentication
5. If ΔE > discontinuity_threshold: terminate session immediately
```

5. Security Analysis

5.1 Threat Model

SITUS assumes a powerful adversary who:

- Has stolen the user's private key
- Can observe all network traffic (active MITM)
- Can spoof individual sensors (GPS, WiFi scan results)
- Has access to commodity hardware and software
- Is **not** physically present at the user's location

5.2 Attack Resistance

Credential Theft (Remote Attacker): Possessing the private key is insufficient. The attacker cannot produce a valid EEV because they are not in the victim's physical environment. Fabricating an EEV requires simultaneously spoofing 6+ sensor channels with internal

consistency — the cross-sensor validation makes this computationally and physically impractical from a remote location.

Replay Attack: Each EEV is timestamped and committed before the challenge is issued. The server maintains a Bloom filter of EEV commitments, rejecting any previously seen commitment. Environmental entropy ensures that even two authentications from the same desk one minute apart produce different EEVs.

Sensor Spoofing: An attacker can spoof one or two sensors (e.g., GPS, WiFi scan). But the CSCV cross-validates all sensors against each other. Spoofing GPS while leaving WiFi and cell tower data authentic creates detectable inconsistencies. Spoofing *all* sensors consistently requires knowledge of the victim's exact physical environment — which requires physical presence, defeating the purpose of the remote attack.

Man-in-the-Middle: The commit-before-challenge protocol ensures that the EEV is fixed before the challenge is revealed. An MITM cannot modify the EEV to match a different environment without invalidating the commitment. The MITM also cannot relay the authentication in real-time because the temporal decay function detects the additional network latency.

Insider Threat (Physical Proximity): SITUS does not protect against an attacker who is physically present at the same location as the victim and has stolen the victim's private key. This is by design — if the attacker is already physically present and has the credential, they are operationally indistinguishable from the legitimate user. This is the explicit boundary condition of the protocol.

6. Comparison with Existing Approaches

Approach	Proves Identity	Proves Location	Replay-Resistant	Non-Transferable	Non-Relocatable
Passwords	Weakly	No	No	No	No
Hardware Tokens (FIDO2)	Yes	No	Yes	Partially	No
Behavioral Biometrics	Yes	No	Yes	Yes	No
GPS Geofencing	No	Weakly	No	N/A	Weakly
SITUS Protocol	**Yes***	**Yes**	**Yes**	**Yes**	**Yes**

** When combined with an identity-proving protocol such as behavioral biometrics.*

SITUS is designed to complement, not replace, identity-proving protocols. The optimal deployment combines behavioral authentication (proving *who* you are) with SITUS (proving *where* you are). Together, they create authentication that is simultaneously non-transferable and non-relocatable.

7. Implementation Considerations

7.1 Privacy

SITUS collects extensive environmental data. Privacy protection is built into the protocol:

- **Feature extraction, not raw data:** Audio is reduced to spectral features. WiFi scans retain BSSIDs but not SSIDs. No personally identifiable information is included in the EEV.
- **Client-side processing:** Raw sensor data never leaves the device. Only the processed EEV and its commitment are transmitted.
- **Server-side amnesia:** The server stores EEV commitments (for replay prevention) but not the EEVs themselves. After verification, the EEV is discarded.
- **Differential privacy:** Noise is added to individual sensor readings before inclusion in the EEV, preventing the server from extracting precise location data while maintaining sufficient entropy for verification.

7.2 Sensor Availability

Not all devices have all sensors. SITUS degrades gracefully: the ATM adjusts requirements based on available sensors. Minimum viable authentication requires at least two independent entropy sources. Desktop computers without accelerometers can use network latency fingerprinting and WiFi environment as minimum sources.

7.3 Battery and Performance

Continuous sensor polling drains batteries. SITUS mitigates this through event-driven harvesting (full EEV collection only at authentication events), lightweight monitoring between authentications (low-power sensors only for the TDF), and cached features for slowly-changing signals refreshed at longer intervals.

8. Applications

Critical Infrastructure Access. Power grids, water treatment facilities, and military systems require operators to be physically present at authorized locations. SITUS provides cryptographic proof of physical presence without invasive surveillance.

Remote Work Policy Enforcement. Organizations requiring work from approved locations can verify compliance without screen recording or GPS tracking. SITUS proves the user is in an approved environment without recording what they are doing in it.

Financial Transaction Authorization. High-value transactions can require environmental consistency — the transaction must originate from an environment the user has previously authenticated from.

Digital Evidence Integrity. Law enforcement and legal proceedings require proving that digital evidence was collected at a specific time and place. SITUS can embed environmental context into evidence metadata, providing cryptographic proof beyond spoofable GPS coordinates.

IoT Device Attestation. IoT devices deployed in specific locations (security cameras, industrial sensors) can use SITUS to prove they have not been physically relocated.

9. Conclusion

Authentication has always been about identity — proving *who* you are. SITUS Protocol adds a second dimension: proving *where* you are, with the same cryptographic rigor applied to identity.

By formalizing environmental entropy as a cryptographic primitive and building a commit-before-challenge protocol around it, SITUS creates authentication that is **non-relocatable** — credentials that work only in the physical context where they are used. Combined with behavioral authentication, this creates a system where an attacker must simultaneously replicate the victim's behavior *and* physical environment — a constraint that makes remote credential exploitation structurally impossible.

The physical world has entropy that the digital world cannot fake. SITUS turns that entropy into a security guarantee.

References

1. Goldwasser, S., Micali, S., and Rackoff, C. (1985). "The Knowledge Complexity of Interactive Proof-Systems." *Proceedings of STOC 1985*.
2. Rasmussen, K.B. and Capkun, S. (2010). "Realization of RF Distance Bounding." *USENIX Security Symposium 2010*.
3. Brandt, J. et al. (2023). "Sensor-Based Authentication: A Survey of Methods and Applications." *ACM Computing Surveys*, 55(3).
4. NIST SP 800-63-4 (2024). "Digital Identity Guidelines: Authentication and Lifecycle Management."
5. Karapanos, N. et al. (2015). "Sound-Proof: Usable Two-Factor Authentication Based on Ambient Sound." *USENIX Security Symposium 2015*.
6. Shrestha, B. et al. (2016). "Drone to the Rescue: Relay-Resilient Authentication using Ambient Multi-sensing." *Financial Cryptography 2014*.
7. Mare, S. et al. (2014). "Zebra: Zero-Effort Bilateral Recurring Authentication." *IEEE Symposium on Security and Privacy 2014*.
8. Truong, H.T. et al. (2014). "Comparing and Fusing Different Sensor Modalities for Relay Attack Resistance in Zero-Interaction Authentication." *IEEE PerCom 2014*.